

RISK ANALYSIS & TARGET PRIORITIZATION

Target: tesla.com

Author: Mehenni May

Date: March 13, 2026 | Companion to: Tesla Attack Surface Recon Report

*This document extends the passive recon findings into security analysis.
It answers: what could an attacker target first, and why?*

1. From Recon to Risk Analysis

Passive reconnaissance identifies assets. Risk analysis answers the question that matters: given everything we found, what should a defender protect first — and what would an attacker target first?

This document applies a three-factor risk model to every significant asset discovered:

Factor	Definition	Why it matters
Likelihood	Probability the asset is exploitable	Dev/staging environments almost always have weaker controls than production
Impact	Damage if the asset is compromised	Vehicle APIs = safety-critical; HR systems = employee PII; staging = low
Visibility	How exposed the asset is publicly	Publicly DNS-resolvable dev/staging environments = high visibility to attackers

Risk rating key:

Rating	Definition
CRITICAL	Immediate attacker priority. Compromise could lead to vehicle control, employee account takeover, or mass data breach.
HIGH	Significant risk. Exploit likely leads to data exposure, lateral movement, or infrastructure access.
MEDIUM	Moderate risk. Useful to an attacker as reconnaissance or stepping stone. Not immediately dangerous.
LOW	Minimal current risk. Document and monitor. Could become higher risk if configuration changes.

2. Asset Risk Analysis

The following table analyzes all significant assets discovered during passive reconnaissance. Assets are ordered from highest to lowest risk.

Asset	Category	Risk	Attack scenario
sso-dev.tesla.com	Auth / SSO	CRITICAL	Dev SSO may have weaker auth, misconfigured CORS, debug endpoints, or exposed credentials. A compromise grants employee-level access.
auth-stage.tesla.com	Authentication	HIGH	Staging auth servers often mirror prod config with relaxed controls. Could expose session handling logic or bypass mechanisms.
mfa-dev.tesla.com	MFA	HIGH	Dev MFA endpoint may accept test codes, have rate limiting disabled, or expose OTP generation logic.
kronos-dev.tesla.com	Workforce Mgmt	HIGH	Kronos manages employee scheduling and HR data. Dev instance (403 on HTTP) suggests IP restriction — but the asset exists and responds.
ownerapi-api.prd.usw	Vehicle API (prod)	HIGH	Production owner API handles vehicle commands (lock, unlock, climate, location). Any auth weakness here is safety-critical.
fleet-api.prd.*	Fleet Management	HIGH	Fleet API across 4 regions (EU, NA, USW, USW2). Handles commercial Tesla fleet operations. Exposed across multiple regions.
MQTT port 8883	Vehicle Telemetry	HIGH	77 IPs exposed on MQTT port. If broker auth is weak, an attacker could subscribe to vehicle telemetry streams (location, speed, battery).
signaling-robotics.eng	Robotics (Optimus)	MEDIUM	Engineering signaling for robotics. Exposed engineering environment could leak internal communication protocols or control interfaces.
www-stg2 / www-uat	Web Staging	MEDIUM	Staging/UAT web environments may expose pre-release features, debug parameters, or internal tooling.
tf-poc.tesla.com	POC Environment	MEDIUM	Proof-of-concept environment — unknown purpose. POCs commonly have no auth or minimal hardening.
diner-api.tesla.com	Tesla Diner	LOW	API for Tesla Diner ordering system. Low risk to core infrastructure but may expose PII (orders, payment metadata).
kronos.tesla.com	Workforce Mgmt	LOW	Production Kronos. Publicly DNS-resolvable but likely properly hardened. Document for monitoring.
199.120.x.x gateways	Network Gateways	LOW	Internal gateway IPs (gpgw1 nodes globally). Exposed via DNS but likely firewall-protected. Monitor for port exposure via Shodan.

3. Detailed Risk Breakdown

3.1 CRITICAL: Authentication & SSO Infrastructure

The single most valuable target category for an attacker against Tesla is the authentication stack. Tesla uses a centralized SSO architecture — compromising any part of it could grant access to employee systems, internal tools, and potentially vehicle management portals.

sso-dev.tesla.com (CRITICAL)

This is the highest-priority finding in the entire recon exercise. A development Single Sign-On endpoint is publicly DNS-resolvable and confirmed live (HTTP 301 to HTTPS). Development environments routinely exhibit:

- Weaker password policies and test credentials left active
- Debug logging enabled — may expose tokens, session data, or stack traces
- Relaxed CORS policies that could enable cross-origin attacks
- Rate limiting disabled on authentication endpoints
- Internal admin functionality not present in production

Why this matters: Tesla's SSO is the key to the kingdom. A successful attack against sso-dev could allow an attacker to understand the token structure, bypass logic, or pivot to production SSO systems.

auth-stage.tesla.com (HIGH)

The staging authentication server mirrors production configuration during pre-release testing. Staging environments are designed to be "production-like" but are often not subject to the same security review processes. Combined with the fact that staging receives new features before they are hardened, this represents a significant attack surface for logic vulnerabilities.

mfa-dev.tesla.com (HIGH)

Multi-factor authentication development endpoint. Real-world MFA dev environments have historically been found to accept static test codes (e.g. "000000"), have rate limiting disabled, or expose QR code generation endpoints that could allow MFA bypass.

3.2 CRITICAL: Vehicle API Infrastructure

ownerapi-api.prd.usw.vn.cloud.tesla.com (CRITICAL)

The Tesla Owner API is the backend that powers the Tesla mobile app — enabling commands including:

- Remote lock and unlock
- Climate control
- Real-time GPS location
- Remote start
- Battery status and charging control

This is a production endpoint. Any authentication vulnerability — token replay, JWT weakness, session fixation — would have direct real-world physical consequences for vehicle safety. This is the highest-impact asset in the inventory despite having a low exploitation likelihood (Tesla almost certainly has strong auth controls here).

fleet-api.prd.* across 4 regions (HIGH)

Tesla's commercial fleet API is exposed across four production regions: EU, NA, USW, and USW2. Fleet operators use this API to monitor and manage commercial Tesla vehicles. Compromise could expose fleet operator credentials, vehicle locations, and operational data for commercial customers.

3.3 HIGH: MQTT Vehicle Telemetry (Port 8883)

Shodan identified 77 Tesla IP addresses (all in the 66.17.0.0/18 range) with port 8883 open. Port 8883 is the standard MQTT over TLS port — used for vehicle-to-cloud telemetry communication.

MQTT brokers require authentication, but historical vulnerabilities in IoT deployments have included:

- Anonymous access enabled (no authentication required to subscribe)
- Wildcard topic subscriptions (subscribe to all vehicle data with "#")
- Weak ACL configurations allowing unauthorized topic access
- Older MQTT brokers with unpatched CVEs

If Tesla's MQTT broker allows even read access to telemetry topics, an attacker could subscribe to real-time data streams from Tesla vehicles including GPS coordinates, speed, battery state, and driving behavior. This would be a massive privacy violation at scale affecting hundreds of thousands of vehicles.

Risk note: Tesla almost certainly has proper MQTT authentication. However, the 77-IP exposure surface is large, and a single misconfigured broker in a staging or testing namespace would be sufficient.

3.4 HIGH: Workforce Management — Kronos

kronos-dev.tesla.com

Kronos (now UKG) is the workforce management system used for employee scheduling, time tracking, and HR operations. The development instance responds with HTTP 403 — indicating it is reachable but access-controlled. Key risks:

- Employee PII: names, schedules, shift data, and potentially compensation data
- Operational security: factory shift schedules could reveal production timelines
- Pivot point: Kronos credentials may be shared with other internal HR systems

The 403 response confirms the service exists and is IP-restricted. This is actually good security posture — but the existence of a publicly-DNS-resolvable dev instance of an HR system is still a finding worth noting.

3.5 MEDIUM: Staging & POC Environments

www-stg2, www-uat2, www-uat, www-dev (MEDIUM)

Multiple staging and UAT versions of the tesla.com website are publicly accessible. While these likely contain only marketing/product content, staging environments have historically been used to:

- Test checkout flows with real payment processing infrastructure
- Stage pre-announcement product reveals (information leakage)
- Serve debug JavaScript bundles with internal API endpoint references

tf-poc.tesla.com (MEDIUM)

This subdomain's purpose is unknown — "tf" could indicate TensorFlow, TeslaFi, or another internal tool. POC (Proof of Concept) environments are by definition experimental and are almost never reviewed by security teams. The unknown purpose combined with the lack of any context makes this a medium-priority investigation target.

signaling-robotics.eng.vn.cloud.tesla.com (MEDIUM)

An engineering namespace for robotics signaling. Given Tesla's active Optimus humanoid robot project, this is likely related to inter-robot or robot-to-cloud communication during development. Engineering namespaces are typically not hardened to production standards and may expose internal protocol details, debug interfaces, or unauthenticated endpoints.

4. High-Value Target Prioritization

This section presents the assets in the order a professional bug bounty hunter or offensive security researcher would approach them. The ordering follows the standard methodology: highest likelihood of finding a vulnerability × highest business impact.

4.1 Priority Stack (P1 → P10)

#	Asset	Category	Why target this first	Risk
P1	sso-dev.tesla.com	Auth/SSO	🔑 Dev SSO publicly reachable — highest value auth target	CRITICAL
P2	auth.tesla.com + auth-stage	Authentication	🔒 Core auth infrastructure + exposed staging	CRITICAL
P3	ownerapi (production)	Vehicle API	🚗 Prod vehicle command API — safety-critical	CRITICAL
P4	MQTT port 8883 (x77 IPs)	Vehicle Telemetry	📡 Vehicle data pipeline — 77 exposed IPs	HIGH
P5	fleet-api.prd.* (4 regions)	Fleet Management	🚚 Commercial fleet control across EU + NA + USW	HIGH
P6	mfa-dev.tesla.com	MFA	🔐 Dev MFA endpoint — auth bypass risk	HIGH
P7	kronos-dev.tesla.com	HR / Workforce	👤 HR system dev instance — employee data	HIGH
P8	signaling-robotics.eng	Robotics	🤖 Optimus/robot signaling — novel attack surface	MEDIUM
P9	tf-poc.tesla.com	POC/Unknown	? Unknown POC — low visibility = risk	MEDIUM
P10	www-stg2 / www-uat / www-dev	Web Staging	🌐 Pre-production web environments	MEDIUM

5. What an Attacker Would Do — Step by Step

This section describes the realistic attack path a motivated threat actor would follow after performing the same passive recon exercise. This is written for defensive awareness — understanding the attacker's perspective is essential for prioritizing defenses.

Step 1 — Initial Access via Dev/Staging Auth (Days 1-3)

Target: sso-dev.tesla.com and auth-stage.tesla.com

- Enumerate endpoints: /login, /oauth/token, /admin, /.well-known/openid-configuration
- Test for default or weak credentials on dev SSO
- Check for JWT weaknesses (algorithm confusion, none algorithm, weak secret)
- Test rate limiting on authentication endpoints
- Look for debug parameters or test user accounts

Step 2 — Enumerate Internal API Structure (Days 3-7)

Target: ownerapi, fleet-api, sentry-api

- Use authenticated session from Step 1 to call Owner API endpoints
- Enumerate available vehicle commands and data endpoints
- Test for IDOR (Insecure Direct Object Reference) — accessing other users' vehicles
- Check API versioning — older /v1/ endpoints may have fewer controls than /v2/

Step 3 — Lateral Movement via MQTT (Days 7-14)

Target: 66.17.x.x IPs on port 8883

- Attempt anonymous MQTT connection to broker
- If auth required: test common MQTT credentials (admin/admin, mqtt/mqtt, tesla/tesla)
- If access gained: subscribe to "#" wildcard topic to enumerate all available topics
- Map vehicle-to-cloud telemetry data structure

Step 4 — Escalation via Workforce Systems (Days 14-21)

Target: kronos-dev.tesla.com

- Identify IP range restriction method — check if VPN or specific IP needed
- If bypassed: attempt default Kronos credentials
- Extract employee data for spear-phishing campaign
- Use HR schedule data to target high-value employees during off-hours

This attack path is entirely theoretical and presented for defensive awareness. Tesla's security team almost certainly has controls at each of these steps.

6. Defensive Recommendations

Based on the passive recon findings, the following defensive measures are recommended:

Recommendation	Details	Priorit y
Remove public DNS for dev SSO	sso-dev.tesla.com should not be publicly DNS-resolvable. Move to internal DNS only or VPN-gated access.	P1
Audit staging auth controls	auth-stage.tesla.com should have equivalent auth controls to production. Remove test credentials. Enable rate limiting.	P1
MQTT broker auth audit	Verify all 77 Shodan-indexed MQTT endpoints require client certificate auth. Disable anonymous access. Audit ACLs.	P2
Remove dev MFA from public DNS	mfa-dev.tesla.com should be behind VPN. Test environments for MFA must never be internet-accessible.	P2
Restrict kronos-dev to internal only	403 response confirms it is reachable. Move to internal DNS. HR system dev environments must not be internet-exposed.	P2
Investigate tf-poc.tesla.com	Unknown POC environment. Identify the purpose and decommission or move behind VPN.	P3
Monitor Shodan continuously	Set up Shodan Monitor alerts for org:"Tesla Motors" — new services appearing on the internet should trigger immediate review.	P3
Certificate transparency monitoring	Subscribe to crt.sh alerts for *.tesla.com — new certificates reveal new infrastructure before it is hardened.	P3

7. Conclusion

The passive recon exercise against tesla.com reveals a mature, enterprise-grade infrastructure with strong perimeter controls. However, the exposure of multiple development and staging environments — particularly sso-dev.tesla.com, auth-stage.tesla.com, and mfa-dev.tesla.com — represents the most actionable attack surface for a motivated threat actor.

The core risk is not in Tesla's production infrastructure (which appears well-hardened) but in the shadow infrastructure of development, staging, and POC environments that are not subject to the same security review processes but are nevertheless reachable from the public internet.

For a bug bounty hunter, the priority order is clear: authenticate systems first (SSO, auth, MFA dev environments), then escalate to vehicle APIs, then investigate MQTT telemetry infrastructure. This path follows the principle of highest likelihood × highest impact.

Mehenni May — Passive OSINT Research Portfolio

All activities were passive and legal. No systems were accessed or exploited.